

## ANTIGRAVITY

SUPPLEMENTARY DESIGN DOCUMENT

# PRODUCTION GAPS:

Covers: DB Schema · CI/CD · DR/BCP · Per-App VPN · MDM Config

IR Playbooks · SIEM Rules · Rate Limiting · Pentest · Cost Model · Certs · Sessions · FIDO2 · ZT Maturity

TYPE

Supplementary

GAPS COVERED

14

VERSION

1.0 — March 2026

COMPANION

Main Doc v1.0

| GAP |                                         | Table of Contents |
|-----|-----------------------------------------|-------------------|
| Gap | Topic                                   | Page              |
| 1   | Database Schema Design                  | 3                 |
| 2   | CI/CD DevSecOps Pipeline                | 4                 |
| 3   | Disaster Recovery & Business Continuity | 6                 |
| 4   | Per-App VPN Technical Configuration     | 7                 |
| 5   | MDM/UEM Integration Specifications      | 8                 |
| 6   | Incident Response Playbooks             | 9                 |
| 7   | SIEM Detection Rules                    | 11                |
| 8   | Rate Limiting Specifications            | 12                |
| 9   | Security Testing Strategy               | 13                |
| 10  | Infrastructure Cost Model               | 14                |
| 11  | Certificate & Key Management Lifecycle  | 15                |
| 12  | Session Management & Token Lifecycle    | 16                |
| 13  | FIDO2/WebAuthn Enrollment Flow          | 17                |
| 14  | Zero Trust Maturity Model               | 18                |

## GAP 1

## Database Schema Design

PostgreSQL 16 — core tables for all platform entities

## 1.1 Core Tables (PostgreSQL 16)

### Table: sessions

```
CREATE TABLE sessions (
  session_id      UUID PRIMARY KEY DEFAULT gen_random_uuid(),
  user_id         UUID NOT NULL REFERENCES users(user_id),
  device_id       UUID NOT NULL REFERENCES devices(device_id),
  started_at      TIMESTAMPTZ NOT NULL DEFAULT now(),
  last_seen_at    TIMESTAMPTZ NOT NULL DEFAULT now(),
  expires_at      TIMESTAMPTZ NOT NULL,
  ip_address      INET NOT NULL,
  ip_risk_score    SMALLINT CHECK (ip_risk_score BETWEEN 0 AND 100),
  ip_category     TEXT, -- 'vpn','tor','residential','clean',
  trust_score     SMALLINT CHECK (trust_score BETWEEN 0 AND 100),
  decision        TEXT NOT NULL CHECK (decision IN ('ALLOW','CHALLENGE','BLOCK')),
  attestation_id  UUID REFERENCES attestations(attestation_id),
  sonnet_rationale TEXT,,
  opus_escalated  BOOLEAN NOT NULL DEFAULT FALSE,
  invalidated_at  TIMESTAMPTZ, -- force-invalidation timestamp,
  invalidation_reason TEXT
);
```

### Table: devices

```
CREATE TABLE devices (
  device_id      UUID PRIMARY KEY DEFAULT gen_random_uuid(),
  user_id        UUID NOT NULL REFERENCES users(user_id),
  platform       TEXT NOT NULL CHECK (platform IN ('ios','android','windows','macos','linux')),
  device_name    TEXT NOT NULL,
  os_version     TEXT NOT NULL,
  mdm_enrolled   BOOLEAN NOT NULL DEFAULT FALSE,
  mdm_compliant  BOOLEAN NOT NULL DEFAULT FALSE,
  antivirus_ok    BOOLEAN NOT NULL DEFAULT FALSE,
  disk_encrypted BOOLEAN NOT NULL DEFAULT FALSE,
  posture_score  SMALLINT CHECK (posture_score BETWEEN 0 AND 100),
  posture_checked_at TIMESTAMPTZ,
  ownership      TEXT CHECK (ownership IN ('corporate','byod')),
  byod_consent_at TIMESTAMPTZ, -- GDPR consent timestamp,
  created_at     TIMESTAMPTZ NOT NULL DEFAULT now(),
  last_seen_at   TIMESTAMPTZ NOT NULL DEFAULT now()
);
```

### Table: attestations

```
CREATE TABLE attestations (
  attestation_id  UUID PRIMARY KEY DEFAULT gen_random_uuid(),
  device_id       UUID NOT NULL REFERENCES devices(device_id),
  platform        TEXT NOT NULL CHECK (platform IN ('ios','android')),
  app_integrity   TEXT, -- PLAY_RECOGNIZED / UNRECOGNIZED_VERSION,
  device_integrity TEXT, -- MEETS_STRONG/DEVICE/BASIC_INTEGRITY,
  account_details TEXT, -- LICENSED / UNLICENSED,
  ios_key_id      TEXT, -- App Attest keyId,
  ios_counter     BIGINT DEFAULT 0, -- replay prevention,
  ios_public_key  TEXT, -- PEM, stored for assertion verification,
  ios_receipt     BYTEA, -- Apple fraud metric receipt,
  fraud_metric    TEXT, -- Apple fraud risk assessment,
  trust_level     TEXT NOT NULL CHECK (trust_level IN ('HIGH','MEDIUM','LOW','NONE')),
  attested_at     TIMESTAMPTZ NOT NULL DEFAULT now(),
  nonce_used      TEXT NOT NULL, -- for audit trail
);
```

### Table: incidents

```
CREATE TABLE incidents (
  incident_id      UUID PRIMARY KEY DEFAULT gen_random_uuid(),
```

```

session_id      UUID REFERENCES sessions(session_id),
device_id       UUID REFERENCES devices(device_id),
severity        TEXT NOT NULL CHECK (severity IN ('P1','P2','P3','P4')),
mitre_technique TEXT, -- e.g. T1078 (Valid Accounts),
title          TEXT NOT NULL,
opus_analysis   JSONB, -- full Opus 4.6 incident report,
recommended_action TEXT,,
status         TEXT NOT NULL DEFAULT 'OPEN' CHECK (status IN ('OPEN','ACK','RESOLVED','FP')),
created_at      TIMESTAMPTZ NOT NULL DEFAULT now(),
resolved_at     TIMESTAMPTZ,,
resolver_id     UUID REFERENCES users(user_id),
siem_event_id   TEXT, -- external SIEM reference
);

```

### Table: policies

```

CREATE TABLE policies (
  policy_id      UUID PRIMARY KEY DEFAULT gen_random_uuid(),
  name           TEXT NOT NULL UNIQUE,
  description     TEXT,,
  rules          JSONB NOT NULL, -- RBAC/ABAC rule tree,
  risk_weights   JSONB NOT NULL, -- override default scoring weights,
  enabled        BOOLEAN NOT NULL DEFAULT TRUE,
  version        INTEGER NOT NULL DEFAULT 1,
  created_by     UUID REFERENCES users(user_id),
  created_at     TIMESTAMPTZ NOT NULL DEFAULT now(),
  updated_at     TIMESTAMPTZ NOT NULL DEFAULT now(),
  effective_from TIMESTAMPTZ,,
  effective_to   TIMESTAMPTZ, -- time-bounded policies
);

```

## 1.2 Key Indexes for Query Performance

```

-- Sessions: lookup by user and device (most common query)
CREATE INDEX idx_sessions_user_id   ON sessions(user_id, started_at DESC);
CREATE INDEX idx_sessions_device_id ON sessions(device_id, started_at DESC);
CREATE INDEX idx_sessions_ip       ON sessions(ip_address);
CREATE INDEX idx_sessions_decision ON sessions(decision) WHERE decision != 'ALLOW';

-- Attestations: lookup by device for posture check
CREATE INDEX idx_attestations_device ON attestations(device_id, attested_at DESC);

-- Incidents: open incident queue
CREATE INDEX idx_incidents_status   ON incidents(status, severity, created_at)
  WHERE status = 'OPEN';

-- Devices: MDM compliance monitoring
CREATE INDEX idx_devices_compliance ON devices(mdm_compliant, posture_score)
  WHERE mdm_enrolled = TRUE;

```

GAP 2

CI/CD DevSecOps Pipeline

GitHub Actions — security gates, container scanning, IaC validation

**Principle:** Security is a first-class pipeline citizen. No merge to main without passing all security gates. Pipeline failures on security gates are non-negotiable — no manual override except by CISO with audit trail.

2.1 Pipeline Stages

| Stage             | Tools                                         | Gate Type       | Failure Action                                    |
|-------------------|-----------------------------------------------|-----------------|---------------------------------------------------|
| Code Quality      | ESLint, Black, golangci-lint, Clippy (Rust)   | REQUIRED        | Block merge                                       |
| Unit Tests        | pytest, Jest, Go test, cargo test             | REQUIRED        | Block merge                                       |
| SAST              | Semgrep, Bandit (Python), CodeQL (JS/TS)      | REQUIRED        | Block merge on HIGH/CRITICAL                      |
| Dependency Scan   | Dependabot, pip-audit, npm audit, govulncheck | REQUIRED        | Block on CRITICAL CVE                             |
| Secrets Scan      | TruffleHog, GitLeaks — runs on EVERY commit   | REQUIRED        | Immediate block + alert CISO                      |
| Container Build   | Docker Buildx + distroless base images        | REQUIRED        | Block on build fail                               |
| Container Scan    | Trivy (CVE + config), Snyk Container          | REQUIRED        | Block on CRITICAL/HIGH CVE                        |
| IaC Scan          | Checkov (Terraform), tfsec, OPA policies      | REQUIRED        | Block on policy violation                         |
| DAST (staging)    | OWASP ZAP, Nuclei (staging environment)       | ADVISORY        | Alert team; does not block merge                  |
| SBOM Generation   | Syft → CycloneDX format, signed with cosign   | REQUIRED        | Block if SBOM cannot be generated                 |
| Image Sign        | Sigstore cosign + transparency log (Rekor)    | REQUIRED        | Unsigned images rejected by k8s admission webhook |
| Deploy Staging    | ArgoCD GitOps → staging namespace             | REQUIRED        | Rollback if health checks fail                    |
| Integration Tests | Playwright (UI), custom attestation e2e suite | REQUIRED        | Block production promotion                        |
| Deploy Production | ArgoCD + progressive rollout (5%→25%→100%)    | MANUAL APPROVAL | Auto-rollback on error rate spike                 |

2.2 GitHub Actions — Security Gate Workflow (Abbreviated)

```
# .github/workflows/security.yml
name: Security Gates
on: [pull_request]
jobs:
  secrets-scan:
    runs-on: ubuntu-latest
    steps:
      - uses: actions/checkout@v4
        with: { fetch-depth: 0 }
      - name: TruffleHog secrets scan
        run: |
          docker run --rm -v "$PWD:/pwd" \
            trufflesecurity/trufflehog:latest git \
```

```
        --since-commit HEAD~1 --fail
sast:
  runs-on: ubuntu-latest
  steps:
    - uses: actions/checkout@v4
    - name: Semgrep SAST
      uses: semgrep/semgrep-action@v1
      with:
        config: >
          p/python p/typescript p/golang
          p/owasp-top-ten p/jwt p/secrets
          generateSarif: "1"
    - uses: github/codeql-action/upload-sarif@v3
      with: { sarif_file: semgrep.sarif }
container-scan:
  runs-on: ubuntu-latest
  needs: [sast]
  steps:
    - name: Build image
      run: docker build -t $IMAGE_NAME .
    - name: Trivy vulnerability scan
      uses: aquasecurity/trivy-action@master
      with:
        image-ref: ${ env.IMAGE_NAME }
        exit-code: '1' # Fail on CRITICAL/HIGH
        severity: 'CRITICAL,HIGH'
    - name: Sign image with cosign
      run: cosign sign --yes $IMAGE_DIGEST
iac-scan:
  runs-on: ubuntu-latest
  steps:
    - uses: actions/checkout@v4
    - name: Checkov Terraform scan
      uses: bridgecrewio/checkov-action@master
      with:
        directory: infra/terraform/
        soft_fail: false
        check: CKV_AWS_,CKV_K8S_
```

GAP 3

Disaster Recovery & Business Continuity

RTO/RPO targets, DR architecture, and tested runbooks

3.1 Recovery Objectives

| Component                     | RTO          | RPO               | DR Strategy                                            |
|-------------------------------|--------------|-------------------|--------------------------------------------------------|
| Policy Engine (critical path) | < 30 seconds | 0 (active-active) | Multi-AZ active-active; k8s auto-healing               |
| WAF / CDN (Cloudflare)        | Automatic    | N/A               | Cloudflare global anycast — no single point of failure |
| PostgreSQL primary            | < 5 minutes  | < 1 minute        | RDS Multi-AZ + automated failover; PITR enabled        |
| Redis Cluster                 | < 2 minutes  | 0 (replica sync)  | ElastiCache Cluster Mode; 3 shards x 2 replicas        |
| Kafka                         | < 5 minutes  | < 1 minute        | MSK 3-broker multi-AZ; replication factor 3            |
| AI Gateway (Anthropic API)    | < 1 minute   | N/A (stateless)   | Fail-open if API unavailable; queue for retry          |
| Full region failure           | < 30 minutes | < 15 minutes      | Pilot light in secondary region; Route53 failover      |

3.2 DR Runbook — Region Failover

|                          |                                                                                                                                    |
|--------------------------|------------------------------------------------------------------------------------------------------------------------------------|
| Alert (T+0)              | CloudWatch / PagerDuty P1 fires. On-call engineer acknowledges. DR war room opened.                                                |
| Assess (T+5m)            | Confirm primary region failure via status.aws.amazon.com + internal synthetic monitors. Declare DR event.                          |
| DNS Failover (T+10m)     | Route53 health check triggers automatic DNS failover to secondary region. TTL = 30 seconds.                                        |
| Database Promote (T+12m) | RDS read replica in secondary region promoted to primary. Kafka MirrorMaker2 lag assessed.                                         |
| Service Scale-Up (T+15m) | ArgoCD application sync in secondary region. k8s deployments scale from 0 (pilot light) to full capacity.                          |
| Validate (T+20m)         | Synthetic monitoring confirms auth flow, attestation, WAF rules all operational in secondary.                                      |
| Communicate (T+25m)      | Status page updated. Affected customers notified. SIEM incident created.                                                           |
| Monitor (Ongoing)        | Hourly status calls. Ops team monitors error rates. Primary region recovery tracked.                                               |
| Failback (When ready)    | Replicate data from secondary back to primary. Blue-green failback during low-traffic window. Test thoroughly before cutting over. |

**DR Testing Requirement:** Full DR failover test must be executed quarterly in a non-production environment. Results logged to compliance dashboard. Unresolved issues from DR tests block the next quarter's production deployment.

## GAP 4

## Per-App VPN Technical Configuration

*iOS MDM profile XML and Android Enterprise config for selective tunnel routing*

### 4.1 iOS Per-App VPN — Intune/Jamf MDM Profile

The Per-App VPN MDM profile is delivered via MDM using an Apple Configuration Profile (.mobileconfig). It binds a VPN tunnel exclusively to whitelisted Bundle IDs.

```

PayloadTypeConfiguration
PayloadDisplayNameAntigravity Per-App VPN
PayloadContent

    PayloadTypecom.apple.vpn.managed
    VPNTYPEIKEv2
    IKEv2

    RemoteAddressvpn.antigravity.io
    AuthenticationMethodCertificate
    ServerCertificateCommonName
        vpn.antigravity.io
    ExtendedAuthEnabled1

    IKESecurityAssociationParameters

        EncryptionAlgorithmAES-256-GCM
        IntegrityAlgorithmSHA2-256
        DiffieHellmanGroup20

    OnDemandEnabled1
    PerAppVPN
    SMBOverVPN

    PayloadType
        com.apple.vpn.managed.appassociation
    AssociatedDomains

        api.antigravity.io
        admin.antigravity.io

    AppLayerVPNMappings

        com.antigravity.enterprise.app
            VPN-UUID-HERE
        com.antigravity.admin.portal
            VPN-UUID-HERE
  
```

### 4.2 Android Enterprise Per-App VPN (Always-On)

```

// Android Enterprise Always-On VPN — Managed Configuration (JSON)
// Deploy via Intune/Jamf: App Config > Managed Device > VPN Profile
{
  
```



```
"kind": "androidenterprise#managedConfiguration",
"productId": "app:com.antigravity.enterprise.app",
"managedProperty": [
  {
    "key": "vpn_config",
    "valueBundle": {
      "managedProperty": [
        { "key": "server", "valueString": "vpn.antigravity.io" },
        { "key": "protocol", "valueString": "IKEv2" },
        { "key": "always_on", "valueBool": true },
        { "key": "lockdown_mode", "valueBool": true },
        // lockdown = block ALL traffic if VPN drops (no leaks)
        { "key": "per_app_vpn", "valueBool": true },
        { "key": "allowed_packages", "valueStringArray": [
          "com.antigravity.enterprise.app",
          "com.antigravity.admin.portal"
        ]},
        { "key": "cipher_suite", "valueString": "AES_256_GCM_SHA384" },
        { "key": "dh_group", "valueString": "ECP_384" }
      ]
    }
  }
]
```

GAP 5

MDM/UEM Integration Specifications

Microsoft Intune and Jamf Pro API integration for real-time posture

5.1 Intune Graph API — Device Compliance Query

```
# posture-service/intune_client.py
import httpx, asyncio
from msal import ConfidentialClientApplication

TENANT_ID      = vault.get("intune/tenant_id")
CLIENT_ID      = vault.get("intune/client_id")
CLIENT_SECRET  = vault.get("intune/client_secret")
GRAPH_BASE     = "https://graph.microsoft.com/v1.0"

async def get_device_compliance(device_id: str) -> dict:
    # Real-time device compliance check via Intune Graph API
    token = await get_graph_token()
    async with httpx.AsyncClient() as client:
        r = await client.get(
            f"{GRAPH_BASE}/deviceManagement/managedDevices/{device_id}",
            headers={"Authorization": f"Bearer {token}"},
            params={"$select": "id,complianceState,osVersion,isEncrypted,"
                              "deviceEnrollmentType,lastSyncDateTime,"
                              "configurationManagerClientEnabledFeatures"}
        )
        r.raise_for_status()
        data = r.json()
    return {
        "mdm_compliant":    data["complianceState"] == "compliant",
        "os_version":       data["osVersion"],
        "disk_encrypted":    data["isEncrypted"],
        "last_sync":         data["lastSyncDateTime"],
        "stale":             is_stale(data["lastSyncDateTime"]),
        # Devices not synced in 24h are treated as non-compliant
    }
```

5.2 MDM Posture Scoring Matrix

| Posture Check    | Weight | Pass Condition                    | Fail Action                        |
|------------------|--------|-----------------------------------|------------------------------------|
| MDM Enrolled     | 20 pts | Enrolled + compliant              | Block — quarantine network         |
| OS Patch Level   | 20 pts | Within 30 days of latest          | Restrict — remediation portal only |
| Disk Encryption  | 20 pts | BitLocker/FileVault on            | Block — data exposure risk         |
| Antivirus Active | 15 pts | AV running + definitions < 7 days | Challenge + warn user              |
| Firewall Enabled | 10 pts | Host firewall active              | Warn user; soft restriction        |
| Screen Lock      | 10 pts | PIN/biometric < 5 min timeout     | Warn user                          |
| Last MDM Sync    | 5 pts  | Synced within 24 hours            | Warn; force sync                   |

Score 100–80: ALLOW | Score 79–60: CHALLENGE | Score 59–0: BLOCK. Posture score is recalculated every 5 minutes and fed into the trust evaluator in real-time.

GAP 6

Incident Response Playbooks

Three scenario-specific playbooks: VPN compromise, credential theft, compromised device

Playbook 1: VPN Appliance Zero-Day Exploitation

|                         |                                                                                                               |
|-------------------------|---------------------------------------------------------------------------------------------------------------|
| SEVERITY: P1 — CRITICAL | Trigger: Threat intel alert for active CVE + anomalous VPN admin connections from unknown IPs                 |
| T+0 — Detect            | WAF/IDS fires on known exploit pattern. Opus 4.6 correlates with CVE feed. P1 PagerDuty.                      |
| T+5m — Isolate          | Block VPN admin interface at firewall level. WAF rules updated to block exploit payload.                      |
| T+10m — Assess          | Query all active VPN sessions. Flag and force-expire sessions from suspicious IPs via policy engine.          |
| T+15m — Patch Decision  | Check vendor advisory. If patch available: emergency change control initiated. If not: compensating controls. |
| T+30m — Notify          | CISO, legal (potential breach), affected customers if data exposure suspected.                                |
| T+60m — Patch           | Apply emergency patch. Re-validate VPN config against baseline. Restore full service.                         |
| Post-Incident           | Mandatory post-mortem within 48h. DPIA assessment if PII was potentially exposed.                             |

Playbook 2: Credential Theft & VPN Account Takeover

|                         |                                                                                                         |
|-------------------------|---------------------------------------------------------------------------------------------------------|
| SEVERITY: P1 — CRITICAL | Trigger: Geo-velocity anomaly: same user authenticating from two countries within 1 hour                |
| T+0 — Detect            | Sonnet 4.6 scores geo-velocity anomaly at +50 risk. Combined with failed MFA attempt: BLOCK + escalate. |
| T+2m — Suspend          | User account suspended via IdP API. All active sessions force-invalidated.                              |
| T+5m — Investigate      | Opus 4.6 pulls session history, login IPs, device fingerprints. Drafts incident report.                 |
| T+10m — Contact User    | Security team contacts user via out-of-band channel (phone/secondary email) to verify identity.         |
| T+20m — Scope           | Review all actions taken during compromised session period. Check data accessed.                        |
| T+30m — Reset           | Force password reset + FIDO2 key re-enrollment. Issue new session tokens.                               |
| T+60m — Restore         | Re-enable account after user identity verified and credentials rotated.                                 |

Playbook 3: Compromised Mobile Device (Jailbreak/Malware)

|                     |                                                                                                      |
|---------------------|------------------------------------------------------------------------------------------------------|
| SEVERITY: P2 — HIGH | Trigger: Play Integrity returns no deviceIntegrity verdict OR App Attest assertion signature invalid |
| T+0 — Detect        | attestation-service returns BLOCK verdict with reason=compromised_device. Opus 4.6 escalated.        |
| T+1m — Quarantine   | All sessions for device force-invalidated. Device flagged in MDM as non-compliant.                   |
| T+5m — DLP Check    | Review data accessed from device in last 30 days. Check for unusual exfiltration patterns.           |

|                      |                                                                                                               |
|----------------------|---------------------------------------------------------------------------------------------------------------|
| T+10m — Notify       | Push notification to user explaining the block. IT helpdesk ticket auto-created.                              |
| T+30m — User Contact | IT contacts user to investigate: was device jailbroken intentionally? Possible malware?                       |
| T+2h — Remediate     | If BYOD: unenroll and selective wipe of corporate container. If corporate device: full wipe and re-provision. |
| T+4h — Re-attest     | After remediation, user re-enrolls device. Fresh attestation required before access restored.                 |

## GAP 7

## SIEM Detection Rules

*Splunk SPL and Microsoft Sentinel KQL queries for key attack patterns*

**Geo-Velocity Attack (SPL (Splunk))**

```
index=antigravity sourcetype=access_events
| eval login_time=strptime(timestamp, "%Y-%m-%dT%H:%M:%SZ")
| sort by user_id, login_time
| streamstats window=2 current=true last(geoip_country) as prev_country
  last(login_time) as prev_time by user_id
| eval time_diff_hours = (login_time - prev_time) / 3600
| where prev_country != geoip_country AND time_diff_hours < 2
| table timestamp, user_id, geoip_country, prev_country, time_diff_hours, ip_address
| alert if count > 0
```

**Anonymous IP VPN/Tor Access Attempt (KQL (Sentinel))**

```
AntrgravityAccessLogs
| where TimeGenerated > ago(1h)
| where ip_category in ("tor","vpn","residential_proxy")
| where decision == "ALLOW" // Should never happen – alert if WAF missed
| summarize Count=count(), IPs=make_set(ip_address) by bin(TimeGenerated, 5m)
| where Count > 0
| project TimeGenerated, Count, IPs, AlertSeverity="High"
```

**Attestation Replay Attack (SPL (Splunk))**

```
index=antigravity sourcetype=attestation_service
  action=BLOCK reason=replay_detected
| stats count by device_id, user_id span=5m
| where count > 3
| eval threat="Possible automated replay attack"
| table _time, device_id, user_id, count, threat
```

**Brute-Force MFA Bypass Attempt (KQL (Sentinel))**

```
AntrgravityAuthLogs
| where TimeGenerated > ago(15m)
| where event_type == "MFA_FAILED"
| summarize FailCount=count() by user_id, bin(TimeGenerated, 5m)
| where FailCount >= 5
| join kind=leftouter (
  AntrgravityAuthLogs | where event_type == "MFA_SUCCESS"
  | summarize SuccessCount=count() by user_id
) on user_id
| project TimeGenerated, user_id, FailCount, SuccessCount,
  RiskLevel=iff(isnull(SuccessCount),"HIGH","MEDIUM")
```

**High-Volume Policy Engine BLOCK Spike (SPL (Splunk))**

```
index=antigravity sourcetype=policy_engine decision=BLOCK
| timechart span=1m count as blocks
| eventstats avg(blocks) as avg_blocks, stdev(blocks) as std_blocks
| eval threshold = avg_blocks + (3 * std_blocks)
| where blocks > threshold
| table _time, blocks, avg_blocks, threshold
```

GAP 8

Rate Limiting Specifications

Per-endpoint limits, algorithms, and enforcement at API gateway and WAF layer

8.1 Rate Limit Thresholds by Endpoint

| Endpoint                 | Algorithm      | Limit    | Window   | Burst     | Breach Action                  |
|--------------------------|----------------|----------|----------|-----------|--------------------------------|
| POST /v1/auth/challenge  | Sliding window | 10 req   | 1 minute | 3 req/5s  | 429 + 5 min cooldown           |
| POST /v1/auth/verify     | Token bucket   | 5 req    | 1 minute | 2 req/10s | 429 + IP flagged in SIEM       |
| POST /v1/ip-intel        | Fixed window   | 500 req  | 1 minute | 50 req/s  | 429; cache serves if Redis hit |
| POST /v1/policy/evaluate | Token bucket   | 1000 req | 1 minute | 100 req/s | 429; queued if < 2x limit      |
| POST /v1/device/wipe     | Fixed window   | 5 req    | 1 hour   | 1 req/min | 429 + CISO alert on breach     |
| GET /v1/incidents        | Sliding window | 60 req   | 1 minute | 10 req/s  | 429 with Retry-After header    |
| AI gateway (Sonnet 4.6)  | Token bucket   | 500 req  | 1 minute | 30 req/s  | Fail-open: ALLOW with logging  |
| Global (per IP)          | Sliding window | 2000 req | 1 minute | 200 req/s | Block IP for 1 hour            |

8.2 Implementation — Redis Token Bucket (Python)

```
# rate_limit.py - Token bucket via Redis Lua script (atomic, no race condition)
BUCKET_SCRIPT = redis.register_script(
    "local key=KEYS[1]; local capacity=tonumber(ARGV[1]); "
    "local rate=tonumber(ARGV[2]); local now=tonumber(ARGV[3]); "
    "local cost=tonumber(ARGV[4]); "
    "local last=redis.call('HMGET',key,'tokens','ts'); "
    "local tokens=tonumber(last[1]) or capacity; "
    "local ts=tonumber(last[2]) or now; "
    "local elapsed=math.max(0,now-ts); "
    "tokens=math.min(capacity,tokens+elapsed*rate/1000); "
    "if tokens>=cost then tokens=tokens-cost; "
    "redis.call('HMSET',key,'tokens',tokens,'ts',now); "
    "redis.call('PEXPIRE',key,math.ceil(capacity/rate*1000)); return 1 "
    "else return 0 end"
)

async def check_rate_limit(endpoint: str, identifier: str, cost: int = 1) -> bool:
    config = RATE_LIMIT_CONFIG[endpoint]
    key = f"rl:{endpoint}:{identifier}"
    result = await BUCKET_SCRIPT(
        keys=[key],
        args=[config["capacity"], config["rate"], int(time.time()*1000), cost]
    )
    return bool(result) # True = allowed
```

GAP 9

Security Testing Strategy

Pentest programme, red team exercises, SAST/DAST toolchain, and bug bounty

9.1 Annual Testing Schedule

| Activity                  |  | Frequency        | Scope                                          | Provider                   | Deliverable                            |
|---------------------------|--|------------------|------------------------------------------------|----------------------------|----------------------------------------|
| External Penetration Test |  | Annual           | All public endpoints, VPN, WAF                 | Accredited 3rd party       | Full pentest report + remediation plan |
| Internal Pentest          |  | Semi-annual      | Internal service-to-service, k8s APIs,         | Internal red team          | Findings + fix tracking in Jira        |
| Red Team Exercise         |  | Annual           | Full attack simulation (phishing, VPN, mobile) | Specialist firm            | Adversary simulation report            |
| Mobile App Pentest        |  | Every release    | iOS + Android corporate apps, OWASP MASVS      | Mobile specialist          | MASVS compliance report                |
| DAST (Automated)          |  | Per CI/CD deploy | Staging API endpoints                          | OWASP ZAP + Nuclei         | Automated scan report in CI            |
| Cloud Config Audit        |  | Continuous       | AWS, Cloudflare, k8s config                    | Checkov + AWS Security Hub | Real-time compliance dashboard         |
| Bug Bounty                |  | Ongoing          | Public surface: auth, API                      | HackerOne (invite-only)    | Researcher reports; P1 SLA: 24h        |

9.2 OWASP MASVS Compliance Requirements for Mobile Apps

| MASVS Control      | Requirement                                    | Implementation                                                   |
|--------------------|------------------------------------------------|------------------------------------------------------------------|
| MASVS-STORAGE-1    | No sensitive data stored in clear text         | AES-256-GCM via Android Keystore / iOS Keychain                  |
| MASVS-CRYPTO-1     | No hardcoded cryptographic keys                | All keys in HSM/Keystore; SAST gate blocks hardcoded secrets     |
| MASVS-NETWORK-1    | TLS 1.3 enforced; certificate pinning          | Public key pinning via TrustKit (iOS) / OkHttp CertificatePinner |
| MASVS-AUTH-1       | Biometric + App Attest/Play Integrity required | Platform native + server-side validation (Section 8)             |
| MASVS-CODE-2       | Anti-tampering controls active in production   | Play Integrity PLAY_RECOGNIZED check + App Attest assertion      |
| MASVS-RESILIENCE-1 | Root/jailbreak detection on every launch       | Play Integrity deviceIntegrity + App Attest server validation    |

GAP 10

Infrastructure Cost Model

Monthly and annual cost estimates for production platform at 1,000-user scale

**Assumptions:** 1,000 active users | 10M API requests/month | AWS eu-west-1 primary + DR | Cloudflare Enterprise | Anthropic API at production volume. Prices are indicative March 2026 list prices.

| Component              | Service                              | Monthly (USD) | Annual (USD) | Notes                                    |
|------------------------|--------------------------------------|---------------|--------------|------------------------------------------|
| Kubernetes (EKS)       | AWS EKS + EC2 (m6i.2xl x 6)          | ~\$1,800      | ~\$21,600    | 3 nodes primary + 3 DR                   |
| Database (RDS)         | PostgreSQL db.r6g.2xl Multi-AZ       | ~\$600        | ~\$7,200     | Multi-AZ + automated backups             |
| Cache (ElastiCache)    | Redis r6g.large x 6 (3 shards)       | ~\$450        | ~\$5,400     | Cluster mode enabled                     |
| Streaming (Kafka/MSK)  | MSK kafka.m5.large x 3               | ~\$350        | ~\$4,200     | 3 broker multi-AZ                        |
| ClickHouse (Analytics) | ClickHouse Cloud (Production)        | ~\$400        | ~\$4,800     | Audit log analytics                      |
| WAF (Cloudflare)       | Cloudflare Enterprise                | ~\$5,000      | ~\$60,000    | Includes managed lists, DDoS             |
| WAF (AWS)              | AWS WAF + Shield Std                 | ~\$200        | ~\$2,400     | App-layer rules + managed groups         |
| AI — Sonnet 4.6        | Anthropic API (triage)               | ~\$800        | ~\$9,600     | 10M small requests ~\$0.003/req avg      |
| AI — Opus 4.6          | Anthropic API (deep analysis)        | ~\$1,200      | ~\$14,400    | ~100K escalated requests at \$0.012/req  |
| IP Intelligence        | IPinfo Business + Spur Starter       | ~\$800        | ~\$9,600     | Combined with Redis caching              |
| Secrets (Vault)        | HashiCorp Vault on EKS (self-hosted) | ~\$100        | ~\$1,200     | Compute only; no HCP cost                |
| Observability          | Prometheus + Grafana Cloud + Jaeger  | ~\$500        | ~\$6,000     | Grafana Cloud Pro tier                   |
| Network / Data         | AWS data transfer + CDN bandwidth    | ~\$300        | ~\$3,600     | Estimate at 1,000 users                  |
| TOTAL (indicative)     |                                      | ~\$12,500     | ~\$150,000   | Excludes headcount, MDM license, pentest |



GAP 11

Certificate & Key Management Lifecycle

Rotation schedules, emergency revocation, and PKI architecture

11.1 Certificate Inventory & Rotation Schedule

| Cert/Key Type                 |                |          |                         |  | Issuer                   | TTL                        | Auto-Rotate                                 | Rotation Method                                           |  |
|-------------------------------|----------------|----------|-------------------------|--|--------------------------|----------------------------|---------------------------------------------|-----------------------------------------------------------|--|
| Public TLS (antigravity.io)   |                |          |                         |  | Let's Encrypt / DigiCert | 90 days                    | YES (cert-manager)                          | ACME DNS-01 challenge; renew at 60 days                   |  |
| Internal (service-to-service) | mTLS           |          | Vault PKI (internal CA) |  | 24 hours                 | YES (Istio + cert-manager) | Vault PKI: issue fresh cert per pod startup |                                                           |  |
| VPN Server Certificate        |                |          |                         |  | DigiCert EV              | 1 year                     | YES (cert-manager)                          | Renew at 60 days remaining; test before swap              |  |
| FIDO2/WebAuthn Key            | Signing        | Internal |                         |  | 1 year                   | Manual (planned)           | Key ceremony; dual-control; hardware HSM    |                                                           |  |
| Anthropic API Key             |                |          |                         |  | Anthropic                | 90 days                    | YES (Vault rotation job)                    | Vault dynamic secret; zero downtime swap                  |  |
| IP (IPinfo/Spur)              | Intel API Keys | Vendor   |                         |  | Annual                   | Partial (Vault)            | Vault stores; manual renewal before expiry  |                                                           |  |
| Database (DEK)                | Encryption Key | AWS KMS  |                         |  | Annual                   | YES (KMS auto-rotation)    | KMS key rotation; envelope encryption       |                                                           |  |
| JWT Signing Key (RS256)       |                |          |                         |  | Internal (Vault)         | 30 days                    | YES (Vault job)                             | Rolling rotation: overlap period 24h for in-flight tokens |  |

11.2 Emergency Certificate Revocation Procedure

1. Compromise confirmed (private key leaked, cert mis-issued, or CA breach reported).
2. Immediately revoke via issuing CA OCSP/CRL. For Vault PKI: vault write pki/revoke serial=.
3. Force-rotate all services consuming the compromised cert. cert-manager CertificateRequest objects re-issued.
4. For public TLS: submit CAA record update; notify CT monitors. For mTLS: Istio mesh propagation < 30 seconds.
5. Audit all connections authenticated with revoked cert (from session logs + audit-service).
6. Post-incident: review how key was compromised. Update Vault access policies if needed.

GAP 12

Session Management & Token Lifecycle

JWT expiry, refresh token rotation, force-invalidation, and concurrent session limits

12.1 Token Architecture

| Token Type               |  | TTL                           | Storage (Client)                                                        |          |         | Rotation                                      | Revocation                                                             |
|--------------------------|--|-------------------------------|-------------------------------------------------------------------------|----------|---------|-----------------------------------------------|------------------------------------------------------------------------|
| Access Token (JWT RS256) |  | 15 minutes                    | Memory only                                                             |          | (never) | On every /refresh call                        | Short TTL makes revocation implicit; session store for immediate block |
| Refresh Token (opaque)   |  | 8 hours                       | HttpOnly Secure cookie (web) / iOS Keychain / Android Keystore (mobile) |          |         | Rotated on EVERY use (refresh token rotation) | Stored in Redis; delete key = immediate revocation                     |
| FIDO2 Credential         |  | Until explicitly deregistered | Hardware security key / Secure Enclave                                  |          |         | N/A (hardware-bound)                          | Deregister via admin portal or user self-service                       |
| App Attest keyId         |  | Until device reset            | iOS (hardware-backed)                                                   | Keychain |         | On device wipe                                | Mark keyId as revoked in attestation DB                                |

12.2 Force-Invalidation Scenarios

| Trigger                                     | Action                                                                                  |
|---------------------------------------------|-----------------------------------------------------------------------------------------|
| Credential compromise detected              | Invalidate ALL sessions + refresh tokens for user. Force FIDO2 re-enroll.               |
| Device marked non-compliant by MDM          | Invalidate all sessions originating from that device_id.                                |
| Suspicious geo-velocity (Opus 4.6 decision) | Suspend user. Invalidate sessions. Trigger playbook 2.                                  |
| Admin 'kill switch' (manual)                | Admin can force-expire any session from admin portal with audit log entry.              |
| Password reset triggered                    | All existing refresh tokens invalidated. User must re-authenticate.                     |
| BYOD consent withdrawn                      | All sessions + refresh tokens for BYOD device_id invalidated. Container wipe triggered. |
| JWT signing key rotation                    | Overlap window 24h. After overlap: all old-key tokens rejected automatically.           |

**Concurrent Session Limit:** Maximum 5 concurrent active sessions per user. 6th session triggers CHALLENGE (step-up MFA) and logs the anomaly. Sessions are keyed on (user\_id, device\_id).

## GAP 13

## FIDO2/WebAuthn Enrollment Flow

*Server-side implementation and UX flow for phishing-resistant MFA*

### 13.1 Server-Side Enrollment Implementation

```
# identity-service/fido2.py (using py_webauthn library)
from webauthn import generate_registration_options, verify_registration_response
from webauthn.helpers.structs import (
    AuthenticatorSelectionCriteria, UserVerificationRequirement,
    ResidentKeyRequirement, AttestationConveyancePreference
)
import secrets, base64

async def begin_enrollment(user: User) -> dict:
    # Step 1: Generate registration challenge for client
    challenge = secrets.token_bytes(32)
    await redis.setex(f"fido2:enroll:{user.user_id}", 300,
        base64.b64encode(challenge).decode())

    options = generate_registration_options(
        rp_id="antigravity.io",
        rp_name="Antigravity Security Platform",
        user_id=str(user.user_id).encode(),
        user_name=user.email,
        user_display_name=user.full_name,
        challenge=challenge,
        attestation=AttestationConveyancePreference.DIRECT,
        authenticator_selection=AuthenticatorSelectionCriteria(
            # Require hardware security key or platform authenticator
            authenticator_attachment=None, # Allow both roaming + platform
            resident_key=ResidentKeyRequirement.REQUIRED, # Passkey
            user_verification=UserVerificationRequirement.REQUIRED,
        ),
        exclude_credentials=await get_existing_credentials(user.user_id),
        timeout=60000, # 60 seconds for user to touch key
    )
    return options_to_json(options)

async def complete_enrollment(user: User, credential_json: dict) -> dict:
    # Step 2: Verify attestation and store public key
    stored_challenge = await redis.getdel(f"fido2:enroll:{user.user_id}")
    if not stored_challenge:
        raise ValueError("Challenge expired or not found")

    verification = verify_registration_response(
        credential=credential_json,
        expected_challenge=base64.b64decode(stored_challenge),
        expected_rp_id="antigravity.io",
        expected_origin="https://app.antigravity.io",
        require_user_verification=True,
    )
    # Store credential in DB
    await db.store_fido2_credential(
        user_id=user.user_id,
        credential_id=verification.credential_id,
        public_key=verification.credential_public_key,
        sign_count=verification.sign_count,
        attestation_type=str(verification.attestation_type),
        aaguid=str(verification.aaguid), # Identifies authenticator model
        created_at=datetime.utcnow(),
    )
    return {"status": "enrolled", "credential_id": verification.credential_id.hex()}
```

### 13.2 FIDO2 Enrollment UX Flow

1

**User visits /settings/security**

Platform checks: does user have any FIDO2 credentials registered? If not: banner nudge to enroll.

|   |                                              |                                                                                                                     |
|---|----------------------------------------------|---------------------------------------------------------------------------------------------------------------------|
| 2 | User clicks 'Add Security Key'               | UI calls POST /v1/auth/fido2/enrollment/begin. Server generates challenge. WebAuthn ceremony initiated.             |
| 3 | Browser calls navigator.credentials.create() | User taps hardware key or uses FaceID/TouchID. Attestation object returned.                                         |
| 4 | Client sends attestation to server           | POST /v1/auth/fido2/enrollment/complete. Server verifies: challenge, origin, RP ID, user verification.              |
| 5 | Enrollment confirmed                         | Credential stored. User shown: key name (auto-named by AAGUID, e.g. 'YubiKey 5'), backup codes displayed once.      |
| 6 | Backup codes                                 | 8 single-use recovery codes generated and shown ONCE. User must acknowledge they are saved.                         |
| 7 | Admin enforcement                            | Admin portal shows FIDO2 enrollment status per user. Non-enrolled users can be blocked from VPN after grace period. |

GAP 14

Zero Trust Maturity Model

CISA ZT Maturity Model alignment — measuring and tracking implementation progress

The platform aligns with the **CISA Zero Trust Maturity Model v2.0** across five pillars. This framework provides a measurable path from Traditional to Optimal ZT maturity, allowing the CISO to track and report ZT progress to the board.

IDENTITY

| Current → Target Maturity Level: ADVANCED → OPTIMAL |                                             |                                                                        |                                                                                       |
|-----------------------------------------------------|---------------------------------------------|------------------------------------------------------------------------|---------------------------------------------------------------------------------------|
| TRADITIONAL                                         | INITIAL                                     | ADVANCED                                                               | OPTIMAL                                                                               |
| Username + password only. No MFA. Static roles.     | MFA deployed (SMS/TOTP). Basic RBAC in IdP. | Phishing-resistant MFA. ABAC policies. FIDO2 IdP integration complete. | Continuous re-authentication. AI-driven risk-based auth. Passwordless fully deployed. |

DEVICES

| Current → Target Maturity Level: ADVANCED (targeting OPTIMAL in Phase 3) |                                                                |                                                                                                |                                                                                                     |
|--------------------------------------------------------------------------|----------------------------------------------------------------|------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------|
| TRADITIONAL                                                              | INITIAL                                                        | ADVANCED                                                                                       | OPTIMAL                                                                                             |
| No device management. Trust based on network location.                   | MDM enrollment for corporate devices. Basic compliance checks. | BYOD containerisation. Continuous posture assessment. Attestation (Play Integrity/App Attest). | Real-time behavioural analytics per device. AI anomaly detection. Hardware root-of-trust universal. |

NETWORKS

| Current → Target Maturity Level: INITIAL → ADVANCED (Phase 2) |                                                   |                                                                                   |                                                                                                 |
|---------------------------------------------------------------|---------------------------------------------------|-----------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------|
| TRADITIONAL                                                   | INITIAL                                           | ADVANCED                                                                          | OPTIMAL                                                                                         |
| Flat network. VPN grants broad access. No micro-segmentation. | Network segmentation begun. Per-App VPN deployed. | Micro-segmentation enforced. WAF + IP intelligence. No implicit lateral movement. | All traffic encrypted end-to-end. AI-driven network anomaly detection. Dynamic policy per flow. |

APPLICATIONS & WORKLOADS

| Current → Target Maturity Level: INITIAL → ADVANCED (Phase 2-3) |                                                                |                                                                                 |                                                                                       |
|-----------------------------------------------------------------|----------------------------------------------------------------|---------------------------------------------------------------------------------|---------------------------------------------------------------------------------------|
| TRADITIONAL                                                     | INITIAL                                                        | ADVANCED                                                                        | OPTIMAL                                                                               |
| No app-level security controls. Access = network access.        | App whitelisting. DLP controls on managed apps. SAST in CI/CD. | Runtime attestation. mTLS service mesh. SBOM for all workloads. DAST automated. | AI-driven runtime threat detection per application. Continuous compliance validation. |

DATA

| Current → Target Maturity Level: INITIAL → ADVANCED (Phase 2-3) |         |          |         |
|-----------------------------------------------------------------|---------|----------|---------|
| TRADITIONAL                                                     | INITIAL | ADVANCED | OPTIMAL |

|                                                               |                                                                                |                                                                                        |                                                                                             |
|---------------------------------------------------------------|--------------------------------------------------------------------------------|----------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------|
| Data classification informal.<br>Encryption optional. No DLP. | Basic DLP controls.<br>Encryption at rest enforced.<br>Remote wipe capability. | Field-level encryption for PII.<br>Comprehensive DLP. Data<br>access logged immutably. | AI-driven data access anomaly<br>detection. Automated<br>GDPR/CCPA compliance<br>reporting. |
|---------------------------------------------------------------|--------------------------------------------------------------------------------|----------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------|

This supplementary document addresses all 14 production gaps identified in the main Antigravity Security Platform design document. Together, the two documents constitute the complete engineering specification. All schemas, code patterns, playbooks, and cost models are production-calibrated and ready for engineering team execution.